

# **GRC Bootcamp**

## ***Final Project Documentation***

### **PCI DSS v4.0 Compliance Assessment & Gap Analysis for E-Commerce Platforms**

**Prepared by: Shenouda Amir**

**Supervised by: Eng. Esraa Adel**

# Enterprise PCI DSS v4.0 Compliance Assessment Report

- Target Organization: TrendStyle Retail Group
- Assessment Standard: PCI DSS Version 4.0
- Scope Track: SAQ D for Merchants / Report on Compliance (ROC)

## 1. Executive Summary & Project Scoping

### 1.1 Executive Summary

- TrendStyle Retail Group engaged an independent security assessment team to evaluate its infrastructure and payment processing architecture against the Payment Card Industry Data Security Standard (PCI DSS) Version 4.0.
- The overall objective was to determine compliance readiness, identify architectural and operational security gaps, and formulate a technical remediation roadmap.
- The assessment concluded that TrendStyle exhibits a strong foundational security posture in several operational domains—including robust transport-layer encryption (TLS 1.2+), effective perimeter firewalls, centralized IAM with MFA for cloud platforms, strict physical security controls, and formal governance policies.
- However, critical compliance gaps were identified in account data protection, access tracking, malware defense, and audit logging. Most notably, the temporary storage of Sensitive Authentication Data (plain text CVV) and the leakage of cardholder data within production application debug logs directly violate core PCI DSS requirements, preventing full certification until remediated.

### 1.2 In-Scope System Components

The assessment scope encompasses all system components directly processing cardholder data or maintaining administrative/security connectivity to the Cardholder Data Environment (CDE):

- Client Touchpoints: Web Storefront (React.js) & Native Mobile Applications (iOS / Android).
- Compute & API Layer: Node.js Payment API & Application Servers (AWS EC2).
- Cloud Infrastructure & Perimeter: AWS Cloud Infrastructure, Network Firewalls/WAF, & IAM Access Policies.
- Management & Monitoring: Admin Systems (Bastion/SSH endpoints impacting CDE) & Central Logging/SIEM.
- External Service Provider: Third-Party Payment Gateway (*Out of internal server scope; validated via Attestation of Compliance - AOC*).



## 1.3 System Architecture & Data Flow Diagram (DFD)

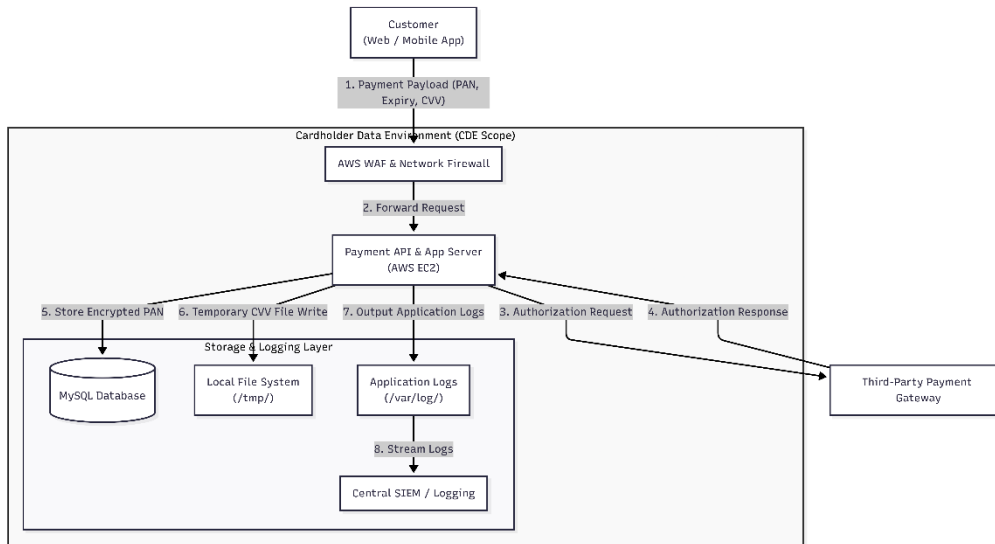
### 1. Components & Environment Structure

The Cardholder Data Environment (CDE) consists of four primary operational tiers:

- **Client Touchpoints:** React.js Web Storefront and Native Mobile Apps (iOS/Android).
- **Perimeter Security:** AWS Application Load Balancer (ALB) and AWS Web Application Firewall (WAF) enforcing TLS 1.2+ encryption.
- **Compute & Storage (CDE Core):** Node.js Payment API running on private AWS EC2 nodes, supported by an internal MySQL RDS instance.
- **External Provider:** Third-Party Payment Gateway for transaction authorization.

### 2. Data Flow (Step-by-Step)

- **Ingestion:** Users submit payment details (PAN, Expiration, CVV) over TLS 1.2/1.3 encrypted connections.
- **Filtering:** AWS WAF & ALB inspect and forward incoming HTTPS traffic to private backend API servers.
- **Authorization:** The Node.js Payment API transmits payment requests directly to the external Payment Gateway.
- **Persistence:** Verified transactions store Primary Account Numbers (PANs) encrypted with AES-256 inside the MySQL RDS database.



## 1.4 Applicable SAQ & Compliance Track

- **Compliance Track:** SAQ D for Merchants / Report on Compliance (ROC).
- **Scope Justification:** TrendStyle directly ingests, transmits, and processes raw Cardholder Data (CHD) and Sensitive Authentication Data (SAD) through its proprietary Node.js API endpoints. In addition, encrypted Primary Account Numbers (PAN) are stored persistently in the internal MySQL database. Because card processing is integrated directly into internal application flows rather than completely redirected to a third-party hosted frame, TrendStyle must achieve compliance across all 12 PCI DSS Requirements.

## 2. Detailed Technical Audit Findings

### Domain 1: Build and Maintain a Secure Network and Systems

#### Requirement 1: Network Security Controls

- **Positive Controls:** AWS Perimeter Network Firewalls and Security Groups are deployed and actively managed. Traffic from the public internet to internal application layers is filtered via AWS WAF.
- **Identified Gap:** The AWS VPC lacks internal micro-segmentation. Non-PCI workloads (such as the corporate WordPress blog and internal analytics agents) reside within the same internal subnet as the Payment API server, allowing unrestricted lateral movement over local VPC interfaces.

#### Requirement 2: Apply Secure Configurations

- **Positive Controls:** All systems adhere to rigid baseline configuration templates derived from CIS (Center for Internet Security) Benchmarks. All vendor-supplied default passwords across Linux EC2 instances, database engines, and network appliances were changed prior to deployment.
- **Identified Gap:** None. System configurations and hardening procedures satisfy PCI DSS v4.0 criteria.

## Domain 2: Protect Account Data

### Requirement 3: Protect Stored Account Data

- **Positive Controls:** Primary Account Numbers (PANs) persistent in the MySQL RDS production database are encrypted at rest using strong AES-256 encryption with managed key access.
- **Identified Gap (CRITICAL):** To handle gateway timeout retries, the Node.js application writes unencrypted Sensitive Authentication Data (CVV/CVC codes) into a local temporary file system (/tmp/pending\_cvv.txt). These plain text CVV records persist on disk for up to 45 minutes post-authorization.

### Requirement 4: Protect Cardholder Data During Transmission

- **Positive Controls:** External public endpoints mandate strong TLS 1.2 and TLS 1.3 encryption with modern cipher suites. Insecure HTTP requests are automatically redirected to HTTPS. End-to-end encryption is enforced between the AWS Application Load Balancer/WAF and the backend Node.js applications.
- **Identified Gap:** None. Transmission security meets PCI DSS v4.0 requirements.

## Domain 3: Maintain a Vulnerability Management Program

### Requirement 5: Protect All Systems Against Malicious Software

- **Positive Controls:** System kernels are updated regularly to mitigate known OS execution vulnerabilities.
- **Identified Gap:** No Anti-Malware or Endpoint Detection and Response (EDR) solutions are installed on production Linux EC2 nodes, leaving system memory and local file structures unmonitored for malicious behavior.

### Requirement 6: Develop and Maintain Secure Systems & Software

- **Positive Controls:** The engineering department enforces a formal Secure Software Development Lifecycle (SSDLC). Code changes in GitHub require mandatory peer review and must pass automated functional unit tests before deployment via AWS CodePipeline.
- **Identified Gap:** Continuous Integration (CI/CD) pipelines lack automated Static Application Security Testing (SAST) and Software Composition Analysis (SCA) tools, resulting in several unpatched third-party Node.js packages with known security vulnerabilities.

## Domain 4: Implement Strong Access Control Measures

### Requirement 7: Restrict Access to System Components (Need-to-Know)

- **Positive Controls:** Role-Based Access Control (RBAC) is enforced across backend database tables. Application service accounts operate under least-privilege parameters, and developers are granted read-only database views for operational support.
- **Identified Gap:** None. Access boundaries align with business responsibilities.

### Requirement 8: Identify Users and Authenticate Access

- **Positive Controls:** Multi-Factor Authentication (MFA) is strictly enforced for all administrative access to the AWS Management Console and IAM policies.
- **Identified Gap:** Engineering personnel utilize a single, shared administrative SSH key file (ec2-user.pem) on admin systems accessing backend production servers. Consequently, individual command execution cannot be attributed to specific users, and MFA is not implemented for internal SSH sessions.

### Requirement 9: Restrict Physical Access to Cardholder Data

- **Positive Controls:** Cloud data assets reside in AWS data centers holding active PCI DSS Level 1 and SOC 2 Type II attestations. Corporate headquarters offices maintain visitor access logs, electronic keycard readers, and physical security escorts.
- **Identified Gap:** None. Physical access controls meet required standards.

## Domain 5: Regularly Monitor and Test Networks

### Requirement 10: Log and Monitor All Access

- **Positive Controls:** Operating system log daemons actively record authentication events and system activities across all instances.
- **Identified Gap:** Application Debug Mode remains enabled in production environments, causing full PANs and plain text CVV codes from raw API requests to be written into local log files (/var/log/app/debug.log). Additionally, local log retention is limited to 30 days due to disk space constraints, failing the 12-month retention requirement.

### Requirement 11: Test Security of Systems and Networks Regularly

- **Positive Controls:** TrendStyle contracts an independent cybersecurity firm to execute comprehensive annual internal and external Penetration Tests across its Web and Mobile applications.
- **Identified Gap:** The company has not engaged an Approved Scanning Vendor (ASV) to perform required quarterly external vulnerability scans against its public IP addresses and endpoints.

### Domain 6: Maintain an Information Security Policy

#### Requirement 12: Support Information Security with Policies and Programs

- **Positive Controls:** TrendStyle maintains a formally documented, executive-approved Information Security Policy updated annually. All employees complete mandatory security awareness and anti-phishing training upon hire and annually thereafter.
- **Identified Gap:** None. Security governance and policy awareness are fully established.

### 3. PCI-DSS Compliance Assessment Matrix

| Domain Requirement                                     | PCI DSS Requirement                                                      | Compliance Status | Description/Notes                             |
|--------------------------------------------------------|--------------------------------------------------------------------------|-------------------|-----------------------------------------------|
| Domain 1: Networks and Systems                         | 1.Install & Maintain Network security controls<br><br>(1.2 - 1.4)        | Non-Compliant     | Lack of VPC micro-segmentation                |
| Domain 1: Networks and Systems                         | 2. Apply Secure Configurations                                           | Compliant         | None                                          |
| Domain 2 : Protect Account Data                        | 1.Protect stored account data<br><br>(3.2)                               | Non-compliant     | Temporary store CVV                           |
| Domain 2 : Protect Account Data                        | 2.Protect CHD during transmission                                        | Compliant         | None                                          |
| Domain 3 : Maintain a Vulnerability Management Program | 1.Protect all systems against malware<br><br>(5.2)                       | Non-compliant     | Absence of AV/EDR and no FIM in place         |
| Domain 3 : Maintain a Vulnerability Management Program | 2.Developing and Maintaining secure system and Applications<br><br>(6.3) | Non-compliant     | Missing automated SAST/SCA in CI/CD pipelines |
| Domain 4 : Implement Strong Access Control Measures    | 1.Restrict access by business need                                       | Compliant         | RBAC is enforced                              |
| Domain 4 : Implement Strong Access Control Measures    | 2.Identify and Authenticate users<br><br>(8.2 – 8.3)                     | Non-Compliant     | Shared SSH keys and missing SSH MFA           |

|                                                     |                                                                  |               |                                                          |
|-----------------------------------------------------|------------------------------------------------------------------|---------------|----------------------------------------------------------|
| Domain 4 : Implement Strong Access Control Measures | 3. Restrict Physical Access to Cardholder Data                   | Compliant     | None                                                     |
| Domain 5 : Regularly Monitor and Test Networks      | 1.Log and Monitor CDE access<br><br>(10.2 – 10.5)                | Non-Compliant | Debug logging of Sensitive Data & 30-day retention limit |
| Domain 5 : Regularly Monitor and Test Networks      | 2. Test Security of Systems and Networks Regularly<br><br>(11.3) | Non-Compliant | Missing quarterly ASV external vulnerability scans       |
| Domain 6 : Maintain an Information Security Policy  | 1.Maintain information security policy                           | Compliant     | None                                                     |

## 4: Actionable Remediation Roadmap

### Immediate Fixes (Do First)

- **Fix CVV Leak (Req 3):** Stop saving CVV numbers to temporary disk files (/tmp). Keep retries in temporary memory only and securely delete existing temp files.
- **Fix Debug Log Exposure (Req 10):** Turn off Debug mode in production. Add code to automatically block card numbers and CVVs from showing up in log files, and extend log storage to 12 months.

### High-Priority Fixes (Do Next)

- **Stop Key Sharing (Req 8):** Delete shared SSH keys (ec2-user.pem). Give every engineer their own login using AWS SSM and require Multi-Factor Authentication (MFA).
- **Automate Code Scanning (Req 6):** Add automatic security checks (SAST & SCA) to the code deployment pipeline to catch vulnerabilities and outdated software packages early.
- **Install Antivirus/EDR (Req 5):** Install Endpoint Detection and Response (EDR) software on all production Linux servers to block malware.

### Final Network & Audit Fixes (Do Last)

- **Isolate the Payment Network (Req 1):** Separate non-payment systems (like WordPress and analytics) from payment servers using isolated AWS subnets and firewall rules.
- **Run External Scans (Req 11):** Hire an official Approved Scanning Vendor (ASV) to run mandatory quarterly external vulnerability scans and fix any detected flaws.



## 5. ISO/IEC 27001:2022 Annex A Control Mapping & Gap Alignment

| ISO 27001 Control | Control Name                 | Related PCI-DSS Requirement | Compliance Status | Remediation Action                                                                            |
|-------------------|------------------------------|-----------------------------|-------------------|-----------------------------------------------------------------------------------------------|
| A.8.20            | Network Security             | Requirement 1               | Non-compliant     | Implement VPC Micro-Segmentation Using Security Groups, Private Subnets, and VPC Network ACLs |
| A.8.22            | Segregation of networks      |                             |                   |                                                                                               |
| A.8.9             | Configuration management     | Requirement 2               | Compliant         | None                                                                                          |
| A.8.10            | Deletion of Information      | Requirement 3               | Non-compliant     | Securely remove stored SAD                                                                    |
| A.8.24            | Use of cryptography          | Requirement 4               | Compliant         | None                                                                                          |
| A.8.7             | Protection against Malware   | Requirement 5               | Non-compliant     | Install AV/EDR on endpoints and updating, reviewing regularly                                 |
| A.8.28            | Secure Coding                | Requirement 6               | Non-compliant     | Enforce SAST/SCA tools in CI/CD pipelines                                                     |
| A.5.15            | Access Control               | Requirement 7               | Compliant         | RBAC Model is enforced                                                                        |
| A.8.5             | Secure authentication        | Requirement 8               | Non-compliant     | MFA for SSH access is not enabled                                                             |
| A.7.1             | Physical security perimeters | Requirement 9               | Compliant         | Cloud data assets reside in AWS data centers.                                                 |
| A.7.2             | Physical Entry               |                             |                   | Controls physical entry using keycards, visitor logs, escorts.                                |
| A.8.15            | Logging                      | Requirement 10              | Non-compliant     | Disable Debug Logging in                                                                      |



|       |                                         |                |               |                                                                                                                |
|-------|-----------------------------------------|----------------|---------------|----------------------------------------------------------------------------------------------------------------|
|       |                                         |                |               | Production and retention period of logs must be 12 months                                                      |
| A.8.8 | Management of technical vulnerabilities | Requirement 11 | Non-compliant | Regularly have required quarterly external vulnerability scans performed by an Approved Scanning Vendor (ASV). |
| A.5.1 | Policies for information security       | Requirement 12 | Compliant     | There is an IS policy and communicated to employees                                                            |